

Governance-Driven Development: Embedding Regulatory Requirements in AI Development Workflows

SIMON JARVERS, Technical University of Munich, Germany

ORESTIS PAPAKYRIAKOPOULOS, Technical University of Munich, Germany

AI governance under the EU AI Act faces a structural misallocation of effort: management-based regulation, combined with the credence-good properties of governance outcomes, pushes resource-constrained organisations toward verification-facing documentation rather than the implementation it is meant to verify. We propose Governance-Driven Development (GDD), a framework that treats AI Act obligations and the requirements of supporting standards for safe AI development as formal specifications for software development work. GDD runs on two nested action cycles. A planning cycle scopes obligations against organisational context to produce specifications. An implementation cycle converts each specification into the artefact it specifies, with traceability back to the regulatory source. AI agents perform template-driven work; humans retain interpretation and accountability. The framework is in early implementation at an AI Startup, with unresolved load-bearing questions around knowledge base architecture and obligation decomposition.

Keywords: AI Governance, AI Regulation, EU AI Act, ISO/IEC 42001, Action Research, Implementation Research, Specification-Driven Development, AI-assisted Software Development

Reference Format:

Simon Jarvers and Orestis Papakyriakopoulos. 2026. Governance-Driven Development: Embedding Regulatory Requirements in AI Development Workflows. In *Proceedings of Fifth European Conference on Algorithmic Fairness (ECAF'26)*. Proceedings of Machine Learning Research, 7 pages.

1 Introduction

The EU AI Act [13] establishes mandatory obligations for high-risk AI systems operating in European markets, covering risk management, data governance, technical documentation, transparency, human oversight, and post-market monitoring. The AI Act is a management-based regulation [9]: it mandates processes rather than prescribing technical outcomes, leaving organisations to determine how compliance is achieved. AI governance outcomes compound this challenge by exhibiting the properties of credence goods, whose quality cannot be verified through inspection [25]. Procedural compliance therefore becomes the primary observable signal for external verification.

These features push compliance infrastructure toward producing artefacts that are auditable rather than implementation supporting. For example, risk registers might come to be structured to demonstrate that risk management has

Authors' Contact Information: Simon Jarvers, Technical University of Munich, Professorship for Societal Computing, Munich, Germany, simon.jarvers@tum.de; Orestis Papakyriakopoulos, Technical University of Munich, Professorship for Societal Computing, Munich, Germany, orestis.p@tum.de.

This paper is published under the Creative Commons Attribution-NonCommercial-NoDerivs 4.0 International (CC-BY-NC-ND 4.0) license. Authors reserve their rights to disseminate the work on their personal and corporate Web sites with the appropriate attribution.

ECAF'26, September 02–September 04, 2026, Ghent, BE

© 2026 Copyright held by the owner/author(s).

occurred rather than to inform design decisions. For resource-constrained organisations, verification documentation crowds out meaningful governance work, since both come from the same compliance budget.

Research on AI governance implementation has produced frameworks at the level of organisational policy and ethical principle [24, 27, 31], yet empirical work testing proposed solutions in deployed contexts is scarce [4, 5, 23]. What is known suggests that the transition from organisational commitments to team-level practice is where governance most often breaks down [2, 20]. Practitioners are largely without tested patterns for redirecting compliance effort from verification-facing documentation to workflow-embedded implementation.

Governance-Driven Development (GDD) treats regulatory obligations from the AI Act and supporting standards for safe AI development as formal specifications for development work, embedding obligation-to-artefact translation in nested action cycles. This extended abstract presents the framework at its current design stage, reports preliminary implementation, and surfaces the load-bearing design questions on which broader validation depends.

GDD's components are largely inherited; the contribution is their arrangement. Treating regulation as a source of requirements is long established in legal requirements engineering, and specification-driven implementation, the action research cycle, and the trustworthy-AI artefact catalogue all build on prior work. The combination is new. GDD nests two action cycles at different granularities, one scoping obligations to organisational context and the other implementing each resulting specification. Human authority is placed at every cycle boundary, where conventional pipelines concentrate a single downstream review. Traceability then follows as a byproduct of the implementation work; the evidence trail is emitted while the work is done and not compiled as a separate deliverable.

2 Governance-Driven Development

GDD adapts Specification-Driven Development¹ to AI governance, taking its cycle structure from the four-phase Action Research model of diagnosis, planning action, taking action, and evaluating action [8]. Its central thesis is that regulatory obligations are structurally analogous to development specifications: they define what a system and its surrounding governance apparatus must do, not how, and can therefore be embedded into development workflows rather than handled as a separate compliance layer. Specifications generated from those obligations are optimised for AI-assisted implementation, which has become the norm in contemporary software development [15, 34], with humans occupying verification and evaluation checkpoints.

The framework runs on two nested cycles (Figure 1). The **planning cycle** operates at AI Management System (AIMS) level. Its knowledge base holds company context: existing policies and procedures, risk and incident registers, technical documentation, and prior implementation-cycle feedbacks. Its inputs are obligations extracted from the EU AI Act and from relevant standards for safe AI development, like ISO/IEC 42001. In the plan phase, an AI agent draws on the knowledge base to scope each obligation to the specific organisation, producing an implementation specification. The planning cycle fires on regulatory change, defined review periods, or major product change.

The **implementation cycle** operates at per-obligation level. Each specification triggers one cycle; the relevant knowledge base narrows to the scope of the obligation, typically the codebase plus relevant references from the

¹We use Specification-Driven Development in its contemporary LLM-era sense, where a structured specification serves as the primary source from which implementation is derived [6, 11, 17, 29].

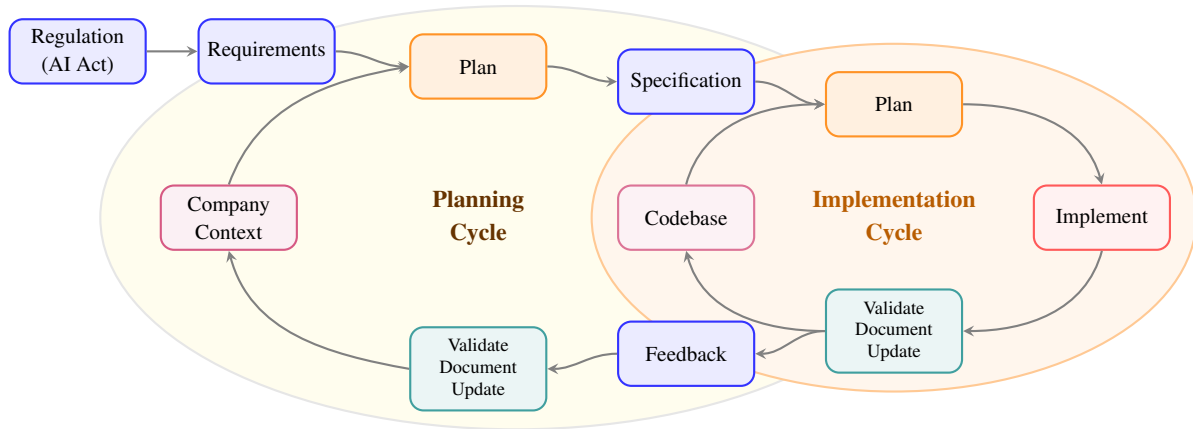


Fig. 1. Governance-Driven Development dual-cycle architecture. The outer planning cycle connects regulation and company context through a plan phase, emits individual specifications, and closes via validate/document/update. Each specification triggers an inner implementation cycle over the codebase, which runs its own plan → implement → validate/document/update.

company context. Cycles may produce code changes (for instance, a logging mechanism satisfying a monitoring obligation), documentation updates, or risk and impact analyses conducted using procedures defined in the AIMS. Each resulting artefact commits with a reference back to its triggering specification and obligation source, establishing the traceability that audit requires.

Human oversight is placed where critical judgement is required: validating the obligation-to-specification transformation, approving implementation plans, supervising judgement-heavy execution, reviewing AIMS updates surfaced by completed cycles, and signing off on audit-relevant artefacts. For verification work that exceeds individual expertise or calls for organisational legitimacy, participatory mechanisms such as the structured expert workshops developed in our prior work on engaged AI governance [20] offer one tested format. Template-driven and high-volume compliance work goes to AI; humans retain interpretation and accountability.

Early proof-of-concept. ISO 42001 requires organisations to communicate their AI policy to relevant interested parties. In the plan phase, the planning agent drew on company context to identify a gap: The organisation maintains a publicly accessible trust centre and that its AI policy had recently been reworked which mandates that the trust centre’s AI policy section needs to be updated. The agent proposed a targeted revision and produced a specification framed as a development ticket, scoping the obligation to the content gap. The generated specification, lightly redacted, took the form of a development ticket:

Title: Update AI policy section on public trust centre
 Obligation: ISO/IEC 42001:2023, Cl. 7.4 (Communication)
 Context: AI policy revised on [date]; trust centre section not yet aligned.
 Task: Update the published trust centre section to reflect the current AI policy. Scope limited to the identified content gap; no change to policy substance.
 Acceptance Criteria: Published section matches the current AI policy; change committed with a reference to this ticket and to the obligation source.

A human reviewer verified and approved the specification, closing the planning cycle and handing the ticket to the implementation cycle. An AI coding agent updated the relevant front-end content; a human reviewed and merged the pull request. On merge, an entry was added to the activity log linking the artefact to the triggering obligation and the approved specification, establishing audit traceability without a separate documentation step. The process ran from obligation identification to merged pull request in approximately two hours. The pilot confirmed the obligation-as-specification mechanic end-to-end. However, this small scale example was of limited complexity and generalisation claims are accordingly bounded.

Although presented against the EU AI Act, the mechanism is in principle **regulation-agnostic**: the same cycle structure applies wherever compound regulatory obligations must be converted into auditable engineering work, with GDPR data protection and product cybersecurity regimes as immediate adjacent cases. The pilot does not evidence this breadth; regulation-agnosticism is a design conjecture here, not a demonstrated property.

Related approaches. GDD builds on several established traditions and on the recent maturation of AI-assisted development. Legal requirements engineering has treated regulation as a source of system requirements, developing methods to extract obligations from legal text [7, 32]; large language models have extended this to obligation extraction and verification at scale [1, 10, 18, 30]. The move from legal text to structured requirements is well-supported; integration of those requirements into ongoing development practice is not. Trustworthy AI assessment forms a second line, producing operational methodologies for translating high-level principles into observable criteria and, more recently, LLM-scaffolded approaches to drafting AI Act conformity documentation oriented toward smaller organisations [12, 14, 16, 22, 33]. The catalogue of artefacts this work generates is comprehensive but remains primarily verification-facing. Regulation-as-code and RegTech automate well-specified rule translation [3, 26], leaving open-textured obligations outside scope. GDD inherits the analytical apparatus and the artefact catalogue from these traditions and exploits AI-assisted development capability to embed both directly within development workflows.

3 Open Questions and Discussion

Several load-bearing design questions remain unresolved:

- (1) **Knowledge base architecture.** The framework depends on the agent receiving clean, well-scoped company context at each cycle stage. We have provisionally adopted Karpathy’s LLM-maintained wiki pattern [21] as a base architecture: three layers (raw sources, compiled wiki, schema document) with ingest, query, and lint operations. Whether the Karpathy pattern is the right base, or whether an alternative retrieval architecture fits governance constraints better, remains open.
- (2) **Obligation decomposition.** AI Act articles and the clauses of supporting standards such as ISO 42001 are compound, cross-referential, and interpretively demanding. The decomposition of raw regulation into addressable units is a non-trivial operation: it may belong to the AI governance officer, an external stakeholder, the development team, the AI agent under human review, or a standing shared library of pre-decomposed obligations. Each placement implies different accountability structures and maintenance burdens.
- (3) **Firing conditions.** The planning cycle’s firing conditions and inter-cycle dependency model are unspecified: implementation cycles are designed to run in parallel, but obligations frequently depend on one another’s feedback, requiring sequencing logic the framework currently lacks.

- (4) **Initialisation.** For a greenfield organisation the planning-cycle knowledge base is empty; templates seed the first iteration, but the path from zero to a knowledge base sufficiently rich to support meaningful obligation scoping needs definition.

Discussion. Future validation is planned through a Design Science Research methodology [19, 28]. We invite researchers to engage on the open design questions above, particularly the knowledge base architecture and obligation decomposition, where progress would shift the framework materially.

A second question deserves explicit framing. Using AI to implement AI governance raises a structural concern: tooling designed to assist compliance may come to resemble the systems it is meant to help govern, weakening the accountability anchor that governance is supposed to provide. However, the realistic alternative for resource-constrained organisations is rarely human-only governance done well; it is governance done partially or performatively. What matters is how to construct development and verification structures within which AI assistance accelerates genuine compliance without displacing the human judgement that governance requires. GDD’s two-cycle architecture is one attempt to draw that line, with AI in template-driven and high-volume work and humans retaining authority over interpretation and accountability. The sharpest threat to that line is automation bias at the human checkpoint. When a reviewer signs off on a stream of agent-generated specifications and artefacts, sign-off drifts toward the formal, which would reinstate the symbolic compliance the framework aims to escape, relocated from the document to the review gate. Keeping the checkpoint genuine, not merely nominal, is therefore itself a design requirement and not only an operational caution. Whether that line holds at scale is a question we hope to engage the AI governance research community on.

References

- [1] Sallam Abualhaija, Marcello Ceci, and Lionel Briand. 2025. Legal requirements analysis: A regulatory compliance perspective. In *Handbook on natural language processing for requirements engineering*. Springer, 209–242.
- [2] Sanna J. Ali, Angèle Christin, Andrew Smart, and Riitta Katila. 2023. Walking the Walk of AI Ethics: Organizational Challenges and the Individualization of Risk among Ethics Entrepreneurs. In *Proceedings of the 2023 ACM Conference on Fairness, Accountability, and Transparency (FAccT ’23)*. Association for Computing Machinery, 217–226. doi:10.1145/3593013.3593990
- [3] Douglas W Arner, János Barberis, and Ross P Buckley. 2017. *FinTech and RegTech in a Nutshell, and the Future in a Sandbox*. CFA Institute Research Foundation.
- [4] Amna Batool, Didar Zowghi, and Muneera Bano. 2025. AI governance: a systematic literature review. *AI and Ethics* 5, 3 (2025), 3265–3279. doi:10.1007/s43681-024-00653-w
- [5] Teemu Birkstedt, Matti Minkinen, Anushree Tandon, and Matti Mäntymäki. 2023. AI governance: themes, knowledge gaps and future agendas. *Internet Research* 33, 7 (06 2023), 133–167. doi:10.1108/INTR-01-2022-0042
- [6] Birgitta Böckeler. 2025. Understanding Spec-Driven-Development: Kiro, spec-kit, and Tessl. martinowler.com, series: Exploring Gen AI. <https://martinowler.com/articles/exploring-gen-ai/sdd-3-tools.html> Published 15 October 2025. The article is authored by Birgitta Böckeler and published within Martin Fowler’s “Exploring Gen AI” series..
- [7] Travis Breau and Annie Antón. 2008. Analyzing regulatory rules for privacy and security requirements. *IEEE transactions on software engineering* 34, 1 (2008), 5–20.
- [8] David Coghlan. 2019. *Doing Action Research in Your Own Organization*. SAGE Publications Ltd, London. <http://digital.casalini.it/9781526481719>
- [9] Cary Coglianese and David Lazer. 2003. Management-based regulation: Prescribing private management to achieve public goals. *Law & Society Review* 37, 4 (2003), 691–730.
- [10] Thiago Dal Pont, Federico Galli, Galileo Sartor, and Giuseppe Contissa. 2025. “Lost in EU Regulation? Don’t Worry, AI Found the Obligation” Extracting and Representing Legal Obligations in the GDPR the DSA and the AI Act. In *Proceedings of the Twentieth*

- International Conference on Artificial Intelligence and Law*. 129–138.
- [11] Den Delimarsky. 2025. Spec-Driven Development with AI: Get Started with a New Open Source Toolkit. The GitHub Blog. <https://github.blog/ai-and-ml/generative-ai/spec-driven-development-with-ai-get-started-with-a-new-open-source-toolkit/> Announcement of the GitHub Spec Kit open-source toolkit (github.com/github/spec-kit). Published 2 September 2025..
 - [12] AI Ethics Impact Group. 2020. From Principles to Practice-An interdisciplinary framework to operationalise AI ethics. *VDE Association for Electrical Electronic & Information Technologies eV, Bertelsmann Stiftung* (2020), 1–56.
 - [13] European Union. 2024. Regulation (EU) 2024/1689 ... (Artificial Intelligence Act). Official Journal of the European Union, OJ L 2024/1689. <https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng> Published 12 July 2024. ELI: <http://data.europa.eu/eli/reg/2024/1689/oj>.
 - [14] Luciano Floridi, Matthias Holweg, Mariarosaria Taddeo, Javier Amaya, Jakob Mökander, and Yuni Wen. 2022. CapAI-A procedure for conducting conformity assessment of AI systems in line with the EU artificial intelligence act. *Available at SSRN 4064091* (2022).
 - [15] GitHub. 2025. Octoverse 2025: A New Developer Joins GitHub Every Second as AI Leads TypeScript to #1. The GitHub Blog. <https://github.blog/news-insights/octoverse/octoverse-a-new-developer-joins-github-every-second-as-ai-leads-typescript-to-1/> Annual state-of-software-development report based on activity from 180 million+ developers. Published 28 October 2025..
 - [16] Delaram Golpayegani, Isabelle Hupont, Cecilia Panigutti, Harshvardhan J Pandit, Sven Schade, Declan O’Sullivan, and Dave Lewis. 2024. AI cards: towards an applied framework for machine-readable AI and risk documentation inspired by the EU AI Act. In *Annual Privacy Forum*. Springer, 48–72.
 - [17] Sean Grove. 2025. The New Code. Talk delivered at AI Engineer World’s Fair 2025. <https://www.youtube.com/watch?v=8rABwKRsec4> Video recording published 11 July 2025. Grove was affiliated with OpenAI at the time of the talk..
 - [18] Shabnam Hassani, Mehrdad Sabetzadeh, Daniel Amyot, and Jain Liao. 2024. Rethinking legal compliance automation: Opportunities with large language models. In *2024 IEEE 32nd International Requirements Engineering Conference (RE)*. IEEE, 432–440.
 - [19] Alan R Hevner, Salvatore T March, Jinsoo Park, and Sudha Ram. 2004. Design science in information systems research1. *MIS quarterly* 28, 1 (2004), 75–106.
 - [20] Simon Jarvers and Orestis Papakyriakopoulos. 2026. Engaged AI Governance: Addressing the Last Mile Challenge Through Internal Expert Collaboration. *arXiv preprint arXiv:2604.21554* (2026).
 - [21] Andrej Karpathy. 2026. LLM Wiki. GitHub Gist. <https://gist.github.com/karpathy/442a6bf555914893e9891c11519de94f> Idea file describing a LLM-maintained personal knowledge bases. Published as a GitHub Gist on 4 April 2026..
 - [22] Jessica Kelly, Shanza Ali Zafar, Lena Heidemann, Joao-Vitor Zacchi, Delfina Espinoza, and Núria Mata. 2024. Navigating the EU AI Act: A methodological approach to compliance for safety-critical products. In *2024 IEEE Conference on Artificial Intelligence (CAI)*. IEEE, 979–984.
 - [23] Blaine Kuehnert, Rachel Kim, Jodi Forlizzi, and Hoda Heidari. 2025. The “Who”, “What”, and “How” of Responsible AI Governance: A Systematic Review and Meta-Analysis of (Actor, Stage)-Specific Tools. In *Proceedings of the 2025 ACM Conference on Fairness, Accountability, and Transparency (FAccT ’25)*. Association for Computing Machinery, 2991–3005. doi:10.1145/3715275.3732191
 - [24] Qinghua Lu, Liming Zhu, Xiwei Xu, Jon Whittle, Didar Zowghi, and Aurelie Jacquet. 2024. Responsible AI Pattern Catalogue: A Collection of Best Practices for AI Governance and Engineering. *ACM Comput. Surv.* 56, 7, Article 173 (April 2024), 35 pages. doi:10.1145/3626234
 - [25] Kira JM Matus and Michael Veale. 2022. Certification systems for machine learning: Lessons from sustainability. *Regulation & Governance* 16, 1 (2022), 177–196.
 - [26] James Mohun and Alex Roberts. 2020. Cracking the code: Rulemaking for humans and machines. *OECD Working Papers on Public Governance* (2020).
 - [27] Jakob Mökander, Maria Axente, Federico Casolari, and Luciano Floridi. 2022. Conformity assessments and post-market monitoring: a guide to the role of auditing in the proposed European AI regulation. *Minds and Machines* 32, 2 (2022), 241–268. doi:10.1007/s11023-021-09577-4
 - [28] Ken Peffers, Tuure Tuunanen, Marcus A Rothenberger, and Samir Chatterjee. 2007. A design science research methodology for information systems research. *Journal of management information systems* 24, 3 (2007), 45–77.
 - [29] Deepak Babu Piskala. 2026. Spec-Driven Development: From Code to Contract in the Age of AI Coding Assistants. *arXiv preprint arXiv:2602.00180* (2026).

- [30] Sarah Santos, Travis Breau, Thomas Norton, Sara Haghighi, and Sepideh Ghanavati. 2024. Requirements satisfiability with in-context learning. In *2024 IEEE 32nd International Requirements Engineering Conference (RE)*. IEEE, 168–179.
- [31] Ben Shneiderman. 2020. Bridging the Gap Between Ethics and Practice: Guidelines for Reliable, Safe, and Trustworthy Human-centered AI Systems. *ACM Trans. Interact. Intell. Syst.* 10, 4, Article 26 (Oct. 2020), 31 pages. doi:10.1145/3419764
- [32] Alberto Siena, John Mylopoulos, Anna Perini, and Angelo Susi. 2009. Designing law-compliant software requirements. In *International conference on conceptual modeling*. Springer, 472–486.
- [33] Francesco Sovrano, Emmie Hine, Stefano Anzolut, and Alberto Bacchelli. 2025. Simplifying software compliance: AI technologies in drafting technical documentation for the AI Act. *Empirical Software Engineering* 30, 4 (2025), 91.
- [34] Stack Overflow. 2025. 2025 Developer Survey. Stack Overflow. <https://survey.stackoverflow.co/2025/> Fifteenth annual survey; 49,000+ responses from 177 countries. Published July 2025..